

ADR 0128 — A settings surface writes through the same fence it reads through

- **Status:** Accepted — implemented, mutation-proved two ways failing differently
- **Date:** 2026-09-06
- **Issue:** #584 (M13.03)
- **Extends:** [ADR 0126](#) (#583) — that ADR's own Consequences section names this exact gap: "A future settings surface (#584 territory) that lets an operator *write* a token still needs its own design — this ADR covers resolution (reading), not provisioning." · docs/SECURITY_MODEL.md 's token-storage row, which this adds a sibling row beside
- **Supersedes / superseded by:** —

Context

#583 (ADR 0126) built a resolver — keyring, then `GIT_VISTA_GITHUB_TOKEN / GH_TOKEN`, then a gitignored file — but no way for a human to set the value it reads, short of editing an environment variable or hand-writing a file at an undocumented path. #584 is that surface: one UI field, and the issue's own framing that the headless path ("`GIT_VISTA_GITHUB_TOKEN`, documented, so a server with no browser attached is fully usable") is worth thinking hardest about.

That headless half needed no new code at all — #583 already built it. The actual design question #584 poses is narrower and sharper: **given a resolver that already knows how to READ from four tiers with a fixed precedence, what may a WRITE touch, and how does a read-side wire guarantee ("never printed") get proven for a NEW read that a browser can trigger on demand, not only at boot?**

A second live constraint shaped the answer: `codex-daybreak` was working #680 (a HIGH-severity credential leak in the clone path — descendants inheriting the token from the environment, clone relaying raw child stderr) in the same file, the same morning. The two efforts needed to be provably non-overlapping without either lane blocking on the other.

Decision

1. The write targets exactly one tier: the OS keyring

`store_token(token: &str) -> Result<(), StoreTokenError>` calls `keyring::Entry::new(KEYRING_SERVICE, KEYRING_USERNAME).set_password(...)` — the same two fixed constants `resolve_token`'s read side already addresses, and nothing else. Two tiers are deliberately unreachable from this surface:

- **The environment-variable tiers are not this process's to rewrite.** `GIT_VISTA_GITHUB_TOKEN / GH_TOKEN` are read from whatever launched this process; a settings surface that could somehow persist a value into a *future* process's environment would be a different, much stranger feature than "save a token."
- **The tier-3 file is a human's manual fallback, not a target the app writes on the user's behalf.** ADR 0126's own doc for `state::token_file_path()` already frames it as a fallback for a machine with no keyring ("set this file's contents... when neither the OS keyring nor `GIT_VISTA_GITHUB_TOKEN / GH_TOKEN` has one"), meant to be edited by hand. Letting the settings UI fall back to writing plaintext there when the keyring fails would make "did this save land somewhere secure" depend silently on which machine it ran on — the same shape of silent degradation ADR 0126 itself flags for the tier's *read* side, but on the write side, worse: a write's caller asked for something to happen and has no way to learn it happened somewhere weaker.

Choosing "keyring only, no negotiated fallback" is therefore not incompleteness — it is the same "the safety lives in the shape, not a list" reasoning ADR 0123 already committed this repository to

for a different value: **the write path's whole security claim is that a saved token lives in a secure store; a path that could quietly not do that is a path with no claim left to make.**

2. A write failure is reported, never folded to `None`

ADR 0126 decision 1 made every *read* fold failure into `None` — a missing D-Bus session, a locked Secret Service, an unset variable, are all indistinguishable from "never configured," because from a resolver's perspective they are. A *write* has no equivalent safe default: the user just asked for a specific thing to happen, and "it silently didn't" is never an acceptable substitute for "it happened." `StoreTokenError` has two variants — `Blank` (client error, `400`) and `Keyring(String)` (server-side failure, `502`, carrying the backend's own diagnostic text) — and the HTTP handler reports one or the other rather than a bare `200` regardless of outcome.

3. The read side reports what is ACTUALLY live, not what this surface last wrote

`token_status()` calls `token_store::resolve_token()` — the exact same function the credential helper uses — rather than checking "does my keyring entry exist." This matters concretely: if a save succeeds and the keyring later becomes unreadable (a D-Bus outage, a locked session — the gap `codex-daybreak`'s #680 audit named independently the same morning, where a keyring failure resolves to `None` silently and a stale `GH_TOKEN` from months ago answers instead), `token_status` reflects whichever tier is *actually* winning right now, live, on every call — never a cached belief about the write that once succeeded.

4. `TokenStatus` cannot carry the value, and that is proved at the wire, not by inspection

The issue's acceptance criterion is explicit: *"The value is never returned by any read endpoint — asserted at the wire level, not by inspection."* Two things make this a proof rather than a claim:

resolve_token,
returns the
resolved token
plus which tier
answered



token_status_of
— pure,
dependency-
injected



builds only:

configured,
masked, source

TokenStatus

serde_json::to_string

the actual HTTP
response body

- **The type.** `TokenStatus { configured: bool, masked: Option<String>, source: Option<String> }` has no field that could hold the resolved `String` — `masked` is always the output of `mask_token`, `source` is always `TokenSource::label()`'s `&'static str`. There is no field to forget to mask.
- **The test.** `token_status_of`'s host tests do not merely construct a `TokenStatus` and inspect its fields — they call `serde_json::to_string(&status)` (the actual wire serialization a client receives) and assert the real secret substring is absent from the **whole serialized value**, for all four resolution tiers, not only the one a hand-picked example might have exercised.

5. Both routes sit behind the full write posture, and never the LAN listener

`GET / POST /api/settings/token` are registered inside `main.rs`'s `if full_routes` block — never on the LAN listener — and classified in `route_authz.rs` (`GET: SessionRequired; POST: SessionAndCsrf`, the same posture as `/api/rescan`). This is a stricter reading of the LAN boundary than most reads get: `/api/rebase-status` (a repository-state read) is registered on *both* listeners, but whether the operator has configured a credential at all — masked or not — is operator-configuration in a way no LAN viewer has a legitimate reason to see, so it stays alongside the write/select/clone endpoints ADR 0005 already reasons about this way.

Alternatives considered

Let a failed keyring write fall back to the tier-3 file. Rejected — decision 1. This is the alternative that most looks like completeness ("at least SOMETHING gets saved") and is exactly the failure mode decision 1 argues against: a save that appears to succeed while silently landing in a weaker store than the one the UI implies.

Report `token_status` from whether the settings surface's own last write succeeded, cached in server state. Rejected — decision 3. This would answer "did I save something" rather than "is a token live right now," and would have reported "configured" straight through the exact #680 - shaped failure (a keyring gone unreadable after a successful save) `codex-daybreak`'s audit flagged. Calling the real resolver costs nothing extra — it is already a fast, local call — and answers the question users actually have.

Mask by inspection only (read the struct definition, confirm no `String` field holds the full value) rather than a runtime wire-level test. Rejected — decision 4, and the issue's own wording ("asserted at the wire level, not by inspection") rules this out explicitly. A structural guarantee and a behavioral proof are different claims; ADR 0115's own finding (a composition site outside either of two well-tested functions could still be wrong) is the general shape of why "the two pieces are each correct" does not imply "the wire format is correct."

Register `GET /api/settings/token` on the LAN listener, like `/api/rebase-status`. Rejected — decision 5. Repository-state reads and operator-credential-configuration reads are different in kind: the former describes what the served repository could do next, which a read-only viewer plausibly wants; the latter describes what the *operator* has configured, which a LAN viewer has no standing to ask about at all, masked or not.

Consequences

- `token_store.rs` gains its first write path since #582/#583 stood up the read side — `store_token`, `StoreTokenError`, `token_status`, `token_status_of` — all additive; `resolve_token`, `resolve_from`, and `mask_token` are unchanged.
- The credential chain now has two independent, non-overlapping efforts touching it the same day: this ADR (provisioning) and #680 (containment — descendants inheriting the token from the environment, clone relaying raw child stderr). Neither modifies the other's surface; `git log` and each PR's own diff are the record of that, not this document's claim alone.
- A future diagnostics surface (`gv doctor`, a CLI flag) that wants to report token status now has `token_status()` ready rather than needing to re-derive provenance from scratch — the same shape ADR 0126's own Consequences section predicted for `provenance_line()`.
- The settings dialog (`dialogs::settings`, wasm-only) is deliberately thin: every decision it needs — the status sentence, whether Save is enabled, what the input field holds after a save settles — lives in `features::settings::core` (framework-free, host-tested), per ADR 0115.
- No change to `docs/SECURITY_MODEL.md`'s existing token-storage row; a new row beside it covers this ADR's surface specifically, so neither becomes stale independent of the other.

Mutation proof

Two arms against `crates/git-vista-server/src/token_store.rs`'s `token_status_of` — the function decision 4's wire-level guarantee rests on — proved via `failure-atlas`'s `mutation_check` (a fresh clone at HEAD, run unmutated then mutated, never touching this working tree), picked to fail differently rather than repeat the same red twice.

arm	mutation	mutated result
leak the value directly	masked: Some(mask_token(&token)) → masked: Some(token) (the full, unmasked value)	caught: token_status_of_present_names_the_source_and_ the exact-match assertion against "...wxyz" , and the wire-lv independently
leak through a different field	source: Some(source.label().to_string()) → source: Some(token.clone()) (the resolved token substituted for the tier label)	caught, and by a different assertion: token_status_of_present_names_the_source_and_masks_t check fails while masked stays correct — proving the wire-lev OTHER new test (token_status_of_never_lets_the_value_reach_the_wire_ is not the only thing standing between this function and a leak

Both caught, neither survived, and the failure shapes are disjoint: arm one is caught on the field the function's whole job is to mask; arm two is caught on a field with no masking responsibility at all, proving the two fields are independently guarded rather than one assertion accidentally covering both. Run key `gv-584-token-status` .

A second mutation-proof pair covers `handlers/settings.rs`'s `store_error_response` — the mapping decision 2 relies on to keep a client mistake and a server-side keyring failure from being reported as the same kind of thing.

arm	mutation	mutated result
collapse both arms to the same status	StoreTokenError::Keyring(_) => (StatusCode::BAD_REQUEST, ...) (report a server failure as a client error)	caught: a_keyring_failure_is_a_server_error_naming_the_backend fails on the status-code assertion, and the_two_error_kinds_map_to_different_status_codes fails independently
drop the backend's diagnostic text	format!("Couldn't save to the OS keyring: {reason}") → a fixed string with no {reason} interpolation	caught: a_keyring_failure_is_a_server_error_naming_the_backend's message.contains("no storage access") assertion fails, while the status-code assertion stays green — a different failure than arm one's

Run key `gv-584-store-error-response` .